

VERITAS

Verifiable Evidence Recovery, Immutable Tamper-proof Audit, and STIX/TAXII-Enabled Sharing
A Forensically Sound Post-Exploitation Pipeline for Cryptographic Sandbox Disposal and Automated Community
Threat-Intelligence Distribution

Research Project Abstract

Domain: Cybersecurity · Digital Forensics · Threat Intelligence

Phase: Post-Exploitation
(Phase 3)

Abstract

Following a malware detonation run inside a sandbox environment, two critical failures recur in existing systems: the infected environment is either retained — creating an unacceptable persistence risk — or destroyed without first preserving forensically admissible evidence, permanently losing volatile artefacts such as decrypted shellcode, injected payloads, and command-and-control encryption keys that exist only in RAM during execution. Neither approach enables the intelligence extracted from the run to be systematically distributed to other organisations in a machine-readable format that allows automated, real-time protection. This work proposes VERITAS — a post-exploitation pipeline operating as Phase 3 of the O-NYX adaptive threat-intelligence platform — addressing all three gaps in a single, sequentially ordered, cryptographically auditable pipeline.

VERITAS performs three sequential operations after a sandbox run concludes. First, it cryptographically seals all volatile evidence — full RAM dump, complete network packet capture, file-system diff, and the AI agent’s forensic report — into a hash-chained, tamper-evident bundle before any disposal step begins. Second, it executes verifiable sandbox disposal: VM hard-termination at the hypervisor level, RAM zeroing, disk cryptoshredding by key destruction rather than file deletion, and full VPC teardown — producing a mathematically verifiable zero-persistence guarantee. Third, the sealed evidence feeds an automated IOC extraction and packaging engine that classifies indicators by sensitivity, packages standard IOCs as STIX/TAXII bundles for instant broadcast to connected organisations via MISP, and routes zero-day candidates through a responsible-disclosure embargo workflow.

VERITAS connects directly to the O-NYX immutable audit store, community sharing router, and org-wide immune system — converting a single detonation event into lasting, community-scale protection.

SIEM alone. Other organisations facing the same threat receive no benefit, and community-level protection latency remains measured in days rather than minutes.

1. Problem Statement

Once a malware analysis run concludes, existing security systems face an unresolved trilemma: retain the infected VM (persistence risk), destroy it immediately (evidence loss), or extract evidence post-hoc from a still-running infected environment (contamination risk). No current system combines immediate forensic sealing, cryptographically verifiable disposal, and automated community-scale intelligence distribution into one sequentially ordered, auditable pipeline.

Three specific gaps drive this sub-problem:

- **Gap 1 — Volatile evidence loss.** Decrypted malware code, injected shellcode, C2 encryption keys, and in-memory behavioural artefacts exist only in RAM during execution. VM termination without a prior memory freeze permanently destroys this evidence — irreversibly, with no recovery path.
- **Gap 2 — Unverifiable disposal.** Deleting a VM image or marking it inactive does not constitute verifiable disposal. Cloud storage systems retain block-level data after logical deletion; malware with sub-OS persistence can survive conventional shutdown. Organisations in regulated industries face liability risk if detonated malware is recovered from decommissioned infrastructure.
- **Gap 3 — Intelligence siloing.** Even when evidence is preserved correctly, extracted threat intelligence — IOC hashes, malicious domains, behavioural TTP signatures — is typically retained within the analysing organisation’s

2. Proposed System Architecture

VERITAS is structured as three sequential, confirmation-gated stages. Each stage must complete and write a cryptographic confirmation to the O-NYX audit chain before the next begins. This sequencing eliminates the race condition present in systems that attempt concurrent evidence extraction and disposal.

Stage 1 — Forensic Evidence Sealing

Immediately upon sandbox run completion — before any VM process is terminated — VERITAS triggers a simultaneous four-channel evidence freeze:

- **Full memory dump.** The complete RAM state is frozen and exported via hypervisor-level introspection, capturing decrypted payloads, injected code segments, active C2 session keys, and runtime behavioural state that would be permanently lost upon VM termination.
- **Network packet capture.** The complete PCAP of all traffic generated during the run is extracted — including C2 beacon sequences, DNS resolution patterns, outbound exfiltration attempts, and lateral movement probes across digital twin nodes.
- **File-system diff.** A complete delta between pre- and post-detonation file system states is recorded: every file created, modified, renamed, or deleted, with timestamps and associated process identifiers.
- **AI agent forensic report.** The O-NYX covert agent's complete batch output — MITRE ATT&CK technique map, behavioural timeline, threat classification verdict, and blast-radius prediction — is exported as a structured JSON artefact.

All four artefacts are concatenated into a single evidence bundle, hashed using SHA-256, and appended to the O-NYX immutable audit chain — a hash-chained, append-only log distributed across three physically separate storage nodes. The bundle is cryptographically signed with the sandbox node's private key before disposal begins, constituting a tamper-evident proof: any post-hoc modification breaks the chain and is immediately detectable.

Stage 2 — Verifiable Cryptographic Sandbox Disposal

Once Stage 1 is confirmed on the audit chain, VERITAS executes four simultaneous disposal operations:

- **VM hard termination.** The sandbox VM is killed at the hypervisor level — not via a guest OS shutdown command, which malware with persistence hooks could intercept — ensuring no cleanup routines run.
- **Memory zeroing.** All RAM blocks previously allocated to the sandbox VM are overwritten with zeros and verified — preventing cold-boot or memory remanence attacks from recovering residual malware state.
- **Disk cryptoshredding.** Rather than deleting the virtual disk image, VERITAS destroys the AES encryption key used to encrypt the VM's storage volume. Raw blocks become permanently unreadable without the key — aligned with NIST SP 800-88 media sanitisation guidelines and suitable for regulated-industry compliance requirements.
- **VPC teardown.** The isolated virtual private cloud network segment, DNS configuration, and all routing rules are torn down and IP address ranges released — eliminating any residual network reachability to the former sandbox environment.

Disposal completion is confirmed by the VERITAS disposal auditor — an independent process verifying zero-byte RAM state, key destruction receipt from the cloud KMS, and VPC deletion confirmation from the provider API — before writing a disposal certificate to the immutable audit log. This certificate is the system's guarantee that no malware persistence is possible.

Stage 3 — IOC Extraction, Sensitivity Classification, and Community Distribution

With disposal verified, the sealed evidence bundle feeds the VERITAS intelligence extraction engine:

- **IOC extraction.** Hashes (MD5, SHA-1, SHA-256) of the malware binary and all dropped files; malicious domains and IPs from the PCAP; registry keys, scheduled tasks, and persistence mechanisms from the file-system diff; and behavioural signatures (auto-generated YARA rules from the memory dump).
- **Sensitivity classification.** Each IOC is classified as a standard threat indicator (known malware family, documented technique) or a zero-day candidate (behaviour not matching any current CVE or ATT&CK technique). Standard

indicators proceed to immediate broadcast; zero-day candidates are flagged for analyst review and routed to the responsible-disclosure workflow.

- **STIX/TAXII 2.1 packaging.** Standard IOCs are packaged as STIX 2.1 bundles and broadcast via a TAXII 2.1 server to all connected organisations and MISP — enabling automated ingestion by partner SIEM, EDR, and firewall systems within minutes of detonation completing.
- **Responsible-disclosure embargo.** Zero-day candidates are packaged into a confidential disclosure report, transmitted to the affected vendor via encrypted channel, and placed under a configurable embargo — defaulting to 90 days — before public release, preventing the platform from inadvertently tipping off other threat actors before a patch exists.

3. Key Contributions / Novelty

- **Confirmation-gated sequential pipeline.** VERITAS enforces a strict Stage 1 → Stage 2 → Stage 3 execution order with cryptographic confirmation gates between stages. This eliminates the race condition in systems that attempt concurrent evidence extraction and disposal, ensuring no volatile artefact is lost.
- **Cryptoshredding as the disposal standard.** VERITAS treats key destruction — not file deletion — as the minimum disposal standard, making storage block recovery structurally impossible. This aligns with NIST SP 800-88 and is suitable for regulated industries (healthcare, finance, government) where provable destruction is a compliance requirement.
- **Sensitivity-split IOC distribution.** Rather than applying a single distribution policy to all intelligence, VERITAS implements a two-track model: standard IOCs broadcast immediately for maximum community protection velocity, while zero-day candidates follow a responsible-disclosure embargo. This split is absent from most existing threat-sharing implementations.
- **Tamper-evident distributed audit chain.** All evidence bundles, disposal certificates, and distribution receipts are written to an append-only, hash-chained log distributed across three physically separate storage nodes. Deletion or alteration of any entry breaks the chain and triggers an automatic alert to an external audit authority — making the log suitable as legal evidence and compliance documentation.
- **Direct integration with O-NYX immune system.** VERITAS's STIX/TAXII output connects directly to O-NYX's org-wide immune system, propagating extracted IOCs to every endpoint automatically — converting one detonation event into a protection rule for all devices on the platform without requiring manual SOC intervention.

4. Integration with O-NYX Platform

VERITAS operates downstream of O-NYX Phase 2 (mid-exploitation) and upstream of three platform components:

O-NYX Component	VERITAS Connection	Direction
Digital twin sandbox + Covert AI agent	Receives: memory dump, PCAP, file-system diff, agent report	Input →
Immutable audit store	Writes: evidence bundle hash, disposal certificate, distribution receipt	Output →
Org-wide immune system	Provides: IOC hashes, malicious domains, behavioural signatures	Output →
Community sharing router	Provides: STIX/TAXII bundles, zero-day disclosure packages	Output →

5. Expected Outcomes and Evaluation Direction

VERITAS targets four measurable outcomes:

- **(i) Evidence completeness rate.** Proportion of volatile artefacts successfully sealed and verified on the audit chain before VM termination, evaluated against a corpus of sandbox runs with deliberately short-duration payloads designed to stress the sealing pipeline.
- **(ii) Disposal verifiability.** Proportion of disposal events for which a cryptographically verifiable disposal certificate is produced and confirmed — measured against systems using only logical VM deletion, verified via storage block recovery attempts.
- **(iii) IOC distribution latency.** Elapsed time from sandbox run completion to STIX/TAXII bundle availability on MISP for connected organisations — targeting sub-10-minute distribution for standard IOCs at steady-state throughput.
- **(iv) Zero-day candidate precision.** Proportion of indicators flagged as zero-day candidates confirmed as genuinely novel by manual analyst review — measuring the false-positive rate of the sensitivity classifier against a ground-truth corpus of known and unknown malware samples.

6. Conclusion

VERITAS addresses the post-exploitation gap left unresolved by most malware analysis systems: the window between the end of a sandbox run and the conversion of that run's evidence into lasting, community-scale protection. By enforcing a confirmation-gated, three-stage pipeline — evidence sealing, cryptographic disposal, and sensitivity-split IOC distribution — VERITAS ensures that no volatile artefact is lost, no malware persistence is possible, and no threat intelligence is siloed within a single organisation when it could protect many.

As Phase 3 of O-NYX, VERITAS completes the platform's self-improving loop: the intelligence it extracts and distributes feeds back into O-NYX's pre-screening engine and digital-twin honeypot configuration, making each successive detonation cycle better-informed than the one before. The system connects to MISP, SIEM, and EDR systems through open, standardised protocols — STIX 2.1 and TAXII 2.1 — that any modern security platform can consume without modification.

What VERITAS builds (module scope)

- Cryptographic evidence sealing pipeline (SHA-256 hash-chaining, audit log writer)
- Verifiable sandbox disposal engine (hypervisor termination, memory zeroing, cryptoshredding, VPC teardown)
- Disposal auditor and certificate generator (cloud KMS integration, API confirmation)
- IOC extraction engine (hash, domain, IP, behavioural YARA auto-generation from memory dump)
- Sensitivity classifier (standard IOC vs. zero-day candidate routing logic)
- STIX/TAXII 2.1 packaging and MISP sync module
- Responsible-disclosure embargo workflow and encrypted vendor notification system